

NorthBridge Technology Solutions Inc.
Information Security Management System

Incident Response Policy
POL-004

DOCUMENT CONTROL	
Policy Title	Incident Response Policy
Policy ID	POL-004
Version	1.0
Date	05/17/2026
Author	Ashkon Irani
Reviewed By	IT Director
Approved By	Chief Executive Officer
Classification	Confidential
Applies To	All employees, contractors, and third-party personnel
Review Frequency	Annual, or following any P1 or P2 security incident
Related Documents	POL-001, POL-003, POL-005, NB-ISMS-004 (RSK-012)
ISO 27001 Controls	5.24, 5.25, 5.26, 5.27, 5.28

1. Purpose

This Incident Response Policy establishes NorthBridge Technology Solutions Inc.'s approach to detecting, reporting, classifying, responding to, recovering from, and learning from information security incidents. A security incident is not a matter of if it will happen but when. Organizations that respond to incidents quickly, consistently, and in a coordinated manner suffer significantly less damage than those that respond in an ad hoc or delayed fashion.

For NorthBridge, the ability to respond effectively to incidents is not only an operational necessity but a contractual obligation. Government of Canada client contracts require NorthBridge to notify clients of confirmed incidents involving Protected B data within defined timeframes. Failure to respond within those timeframes constitutes a contract breach regardless of the technical outcome

of the incident. This policy ensures that everyone at NorthBridge knows exactly what to do, who to contact, and how quickly to act when an incident occurs.

This policy directly addresses risk RSK-012 (failure to notify GoC client of a security incident within SLA) as documented in the NorthBridge Risk Register (NB-ISMS-004).

2. Scope

This policy applies to:

- All NorthBridge employees, contractors, consultants, and third-party personnel who discover, suspect, or are involved in a security incident
- All information assets within the ISMS scope as defined in NB-ISMS-001, including all systems, data, networks, facilities, and people
- All types of security incidents including cyberattacks, data breaches, physical security events, insider threats, and accidental data exposures
- All geographic locations where NorthBridge operates, including the Ottawa headquarters and remote working environments

3. Definitions

The following terms are used throughout this policy with specific meanings that are important to understand before an incident occurs.

Term	Definition
Security Event	Any observable occurrence on a system or network. Events are normal and occur constantly. Most events are benign. An event becomes an incident when it is confirmed or suspected to have a negative impact on the organization.
Security Incident	A confirmed or suspected violation of information security policies, acceptable use policies, or standard security practices that has or could have a negative impact on the confidentiality, integrity, or availability of NorthBridge or client information assets.
Data Breach	An incident in which Protected B, Confidential, or Restricted information is accessed, disclosed, altered, or destroyed by an unauthorized party, whether internal or external to NorthBridge.
Near Miss	An event that had the potential to become a security incident but did not cause harm due to chance, detection, or intervention. Near misses must be reported and investigated to prevent future incidents.
Incident Responder	A member of the Incident Response Team is designated to investigate and respond to a specific incident. Led by the IT Director for all P1 and P2 incidents.
Containment	Actions taken to limit the spread or impact of an active incident. The primary goal of the initial response phase. Containment must not destroy forensic evidence unnecessarily.
Eradication	Actions taken to remove the root cause of an incident from the environment, such as removing malware, closing a vulnerability, or revoking compromised credentials.
Recovery	Actions taken to restore affected systems and services to normal operation after the threat has been eradicated, and the environment is confirmed to be clean.

Chain of Custody

The documented and unbroken record of who has handled digital or physical evidence from the time of collection to the time of use in a legal or regulatory proceeding.

4. Incident Classification

Not all incidents are equal. NorthBridge uses a three-tier classification system to prioritize incidents and ensure that the most severe events receive an immediate and proportionate response. Classification is assigned at the time of initial report and may be upgraded or downgraded as more information becomes available during the investigation.

Priority	Level	Criteria	Examples
P1	Critical	Confirmed or highly likely breach of Protected B Government of Canada data. Active ransomware or destructive malware on production systems. Complete loss of availability of client-facing systems. Confirmed compromise of privileged administrator credentials.	Ransomware encrypting production Azure environment. Confirmed exfiltration of GoC client project data. Admin account takeover. Destructive attack on source code repositories.
P2	High	Suspected but unconfirmed data breach. Malware detected and contained on one or more endpoints. Significant but recoverable loss of system availability. Unauthorized access to Confidential systems without confirmed data exfiltration.	Phishing email with confirmed credential entry by an employee. Malware detected by EDR on a developer laptop. VPN anomaly suggests an unauthorized access attempt. Unauthorized access to source code repository by a former employee.
P3	Low	Policy violation with no confirmed data exposure. Phishing email received and reported but not acted upon. Minor system availability disruption with no client impact. Physical security anomaly with no confirmed unauthorized access.	Employee clicks phishing link, but MFA prevents account access. Laptop reported lost with full disk encryption confirmed active. Visitors found in an unauthorized area. Failed brute-force attack blocked by account lockout policy.

When in doubt, classify higher. It is always better to initiate a P1 response and downgrade to P2 after investigation than to underreact to a genuine P1 incident. The cost of an unnecessary escalation is significantly lower than the cost of a delayed response to a major breach.

5. Incident Response Team

The Incident Response Team (IRT) is activated for all P1 and P2 incidents. For P3 incidents, the IT Manager handles the response with IT Director oversight. The IRT consists of the following

standing members, with the ability to add subject matter experts as required by the specific incident type.

Role	Filled By	Incident Response Responsibilities
Incident Commander	IT Director	Overall, accountability for the incident response. Makes all critical decisions including containment actions, client notifications, and law enforcement referrals. Only individual authorized to declare an incident resolved. Available 24/7 for P1 incidents.
Technical Lead	IT Manager	Leads technical investigation and evidence collection. Directs containment and eradication activities. Maintains the incident log. Coordinates with external technical support including MSSP and Microsoft support if required.
Communications Lead	CEO or designated delegate	Manages all external communications including client notifications, regulatory notifications, media inquiries, and law enforcement contact. All external communications must be approved by the Communications Lead before being sent. No other team member may communicate externally about an incident without approval.
Legal and Compliance	External Legal Counsel	Advises regulatory notification obligations under PIPEDA and GoC contracts. Review all external communications before release. Advises evidence of preservation and chain of custody requirements. Manages legal hold if litigation is possible.
HR Representative	HR Manager	Involved in incidents with an insider threat component. Manages any disciplinary process arising from the incident. Ensures employee rights are respected during investigation activities.
Subject Matter Expert	Asset Owner or relevant technical specialist	Provides expertise specific to the systems or data affected by the incident. Engaged as needed based on the nature of the incident. May include cloud architects, developers, or external forensic specialists.

6. Incident Response Lifecycle

NorthBridge's incident response follows a six-phase lifecycle. Each phase has defined objectives, actions, and timeframes. The phases are sequential, but practice phases may overlap, and the team may return to an earlier phase if new information emerges during the investigation.

Phase 1 - Detection and Identification

An incident begins when a security event is detected or reported. Detection may come from automated alerting (SIEM, EDR, MDM), a report from an employee, a notification from a third party such as Microsoft or a client, or discovery during routine monitoring or audit activity.

Detection timeframe targets:

- Automated detection via SIEM or EDR alerts: immediate upon alert generation

- Employee-reported incidents: within 1 hour of the employee becoming aware
- Third-party notifications: within 1 hour of receipt of notification

Upon detection, the individual who discovers or suspects an incident must:

- Not attempt to investigate or remediate the incident independently
- Not power off affected systems unless directed to do so by the IT Director, as this may destroy volatile forensic evidence
- Not communicate about the incident via email or messaging systems that may themselves be compromised
- Contact the IT Director immediately by phone using the emergency contact number maintained on the NorthBridge intranet
- Document the time, nature, and source of their discovery in writing as soon as it is safe to do so

Phase 2 - Initial Assessment and Classification

Upon notification, the IT Director conducts an initial assessment to determine whether a security event constitutes a reportable security incident and assigns a priority classification using the criteria in Section 4.

The initial assessment must be completed within the following timeframes from the point of notification:

Priority	Initial Assessment Timeframe	IRT Activation Timeframe
P1 -- Critical	Within 30 minutes of notification	Immediately upon P1 classification
P2 -- High	Within 2 hours of notification	Within 1 hour of P2 classification
P3 -- Low	Within 4 hours of notification	IT Manager handles; IT Director informed within 4 hours

If the IT Director is unavailable, the IT Manager assumes the Incident Commander role and contacts the IT Director as soon as they are reachable. The CEO must be notified of all P1 incidents within 1 hour of classification.

Phase 3 - Containment

Containment limits the spread and impact of the incident. There are two forms of containment that may be applied depending on the nature and severity of the incident.

Short-term containment actions include:

- Isolating affected systems from the network without powering them off where forensic evidence may be required
- Revoking compromised credentials and forcing password resets for affected accounts
- Blocking malicious IP addresses, domains, or email sender addresses at the perimeter
- Disabling compromised VPN certificates or accounts
- Suspending access for accounts suspected of being involved in an insider threat

Long-term containment actions that may be required for extended incidents include:

- Rebuilding compromised systems from known-good images while preserving the original for forensic analysis
- Temporarily restricting access to affected systems to a minimal set of users
- Implementing additional monitoring on potentially affected systems and accounts
- Engaging external incident response support from a Managed Security Service Provider if the incident exceeds internal response capacity

During containment, the Technical Lead must maintain a detailed and timestamped incident log recording every action taken, every system touched, and every decision made. This log is a legal document and must be treated as such from the moment containment begins.

Phase 4 - Investigation and Evidence Collection

The investigation phase determines the root cause of the incident, the full scope of impact, whether data was accessed or exfiltrated, and which systems and individuals were affected.

Evidence collection requirements:

- All digital evidence must be collected in a forensically sound manner that preserves its integrity and admissibility. Where possible, forensic copies of affected systems are taken before any remediation actions are performed
- Chain of custody must be maintained for all evidence from the moment of collection. Every person who handles evidence must be documented
- Logs from all relevant systems including Azure Active Directory, Microsoft 365, VPN, EDR, and Azure Monitor must be collected and preserved immediately, as logs may be overwritten if retention periods are short
- Screenshots, system outputs, and other documentary evidence must be labelled with the date, time, and the name of the person who collected them
- If criminal activity is suspected or if a government client has been affected, Legal Counsel must be engaged before any investigative actions that could affect evidence admissibility

The Technical Lead documents findings in the incident record and provides a written investigation summary to the Incident Commander before any eradication activities begin. Eradication must not commence until the investigation has determined the full scope of the incident; otherwise, the threat may persist in unidentified systems.

Phase 5 - Eradication and Recovery

Eradication removes the threat from the environment. Recovery restores normal operations. These phases may overlap, but eradication must be confirmed before any restored systems are returned to production.

Eradication activities include:

- Removing malware, unauthorized accounts, backdoors, and other artifacts introduced by the attacker
- Patching or mitigating the vulnerability that was exploited to gain initial access

- Revoking and rotating all credentials that may have been exposed or compromised during the incident
- Rebuilding systems from clean images where the integrity of an affected system cannot be confirmed

Recovery activities include:

- Restoring systems from verified clean backups where data has been corrupted or destroyed
- Validating that restored systems are clean and fully patched before returning them to production
- Confirming that security monitoring is active and functional on all recovered systems before declaring recovery complete
- Conducting a final validation scan using EDR and vulnerability scanning tools before returning systems to client-facing production

The Incident Commander must formally authorize the return of each affected system to production. No system may be returned to production without this authorization.

Phase 6 - Post-Incident Review

Every P1 and P2 incident must be followed by a formal post-incident review conducted within 5 business days of incident resolution. P3 incidents are reviewed at the next scheduled quarterly risk review.

The post-incident review produces a written Post-Incident Report containing:

- A complete timeline of the incident from initial detection through resolution
- Root cause analysis identifying the vulnerability, threat, and control failure that enabled the incident
- Full scope of impact including systems affected, data accessed or exfiltrated, and business impact
- Assessment of the effectiveness of the incident response including what worked well and what did not
- Specific remediation actions with owners and completion dates to address identified gaps
- Recommendations for improvements to security controls, policies, or procedures to prevent recurrence

The Post-Incident Report is reviewed and approved by the IT Director and presented to the CEO within 10 business days of incident resolution. Findings that require immediate control improvements are added to the Risk Register and treated as High or Critical risks until remediated.

7. Client and Regulatory Notification

Notification of affected parties is one of the most time-sensitive and legally significant aspects of incident response. NorthBridge has contractual and regulatory obligations that require notification within defined timeframes. Failure to notify within those timeframes is a breach of contract or regulatory requirement, independent of the incident itself.

7.1 Government of Canada Client Notification

When a confirmed or highly suspected security incident involves Government of Canada client data or systems, the following notification requirements apply:

Scenario	Notification Requirement	Timeframe
Confirmed breach of Protected B client data	Formal written notification to the designated client security contact and the client's Departmental Security Officer (DSO). Notification must confirm the nature of the breach, systems and data affected, and actions taken.	Within 1 hour of P1 classification for verbal notification. Formal written notification within 24 hours.
Suspected breach of Protected B client data (under investigation)	Preliminary notification to the client security contact advising that an incident is under investigation and that Protected B data may be involved. Update notifications every 4 hours until resolved.	Within 2 hours of classification as a potential data breach incident.
Incident affecting client system availability only (no data breach)	Notification to client project manager and technical lead advising of the outage, estimated recovery time, and actions being taken.	Within 1 hour of confirmed client service impact.

Client notification contact details are maintained in the NorthBridge Client Security Contact Register, which is stored in the Restricted access site on SharePoint and updated at the start of each client engagement. The IT Director is responsible for ensuring that this register is always current.

7.2 Regulatory Notification

The following regulatory notifications may be required depending on the nature and scope of the incident. Legal Counsel must advise applicability before any regulatory notification is made.

Regulator	Notification Trigger	Timeframe
Office of the Privacy Commissioner of Canada (OPC)	Any breach of personal information under PIPEDA that poses a real risk of significant harm to affected individuals.	As soon as feasible after, it is reasonable to believe that a reportable breach has occurred. No defined statutory timeframe, but prompt notification is expected.
Canadian Centre for Cyber Security (CCCS)	Significant cyber incidents affecting Government of Canada systems, networks, or contractors. Voluntary reporting is strongly encouraged for incidents affecting federal contractors.	As soon as possible, following a confirmed significant incident. CCCS reporting is a best practice and may be contractually required.
Treasury Board Secretariat	Incidents involving Government of Canada information systems or data as directed by contract terms.	Per contract-specific requirements. The IT Director confirms applicable timeframes with Legal Counsel for each engagement.

7.3 Internal Notification

The following internal notifications must be made for all P1 and P2 incidents:

Recipient	Content	Timeframe
Chief Executive Officer	Incident classification, initial scope assessment, containment status, and notification obligations triggered.	Within 1 hour of P1 classification. Within 4 hours of P2 classification.
Incident Response Team	Full incident brief including known facts, suspected scope, and initial response actions underway.	Immediately upon IRT activation.
Affected Department Heads	Notification that systems in their area are affected. Instructions for staff regarding system use restrictions during the incident.	Within 2 hours of containment of actions that affect their team.
All Staff (if required)	High-level notification that a security incident is being investigated, with specific instructions for staff actions if applicable. No detail that could assist the attacker is included.	Only if staff action is required. Approved by Communications Lead before release.

8. Incident Response Timeframes Summary

The following table provides a consolidated reference for all key timeframes in this policy. This table is intended for use as a quick reference during an active incident.

Action	P1 -- Critical	P2 -- High
Initial assessment completed	30 minutes	2 hours
IRT activated	Immediately	1 hour
CEO notified	1 hour	4 hours
Containment actions initiated	1 hour	4 hours
GoC client verbal notification (if data breach suspected)	1 hour	2 hours
GoC client written notification	24 hours	24 hours
Investigation summary to Incident Commander	4 hours	24 hours
Post-incident review completed	5 business days	5 business days
Post-incident report to CEO	10 business days	10 business days

9. Evidence Handling and Chain of Custody

Evidence collected during incident response may be required in legal proceedings, regulatory investigations, or client audits. Improper evidence handling can render evidence inadmissible and

expose NorthBridge to legal risk. The following requirements apply to all evidence collected during an incident.

- Digital evidence must be collected using forensically sound methods that do not alter the original data. Where possible, forensic images are taken and investigation is conducted on the copy, not the original
- Every piece of evidence must be labelled with the date and time of collection, the name of the individual who collected it, the system or source it was collected from, and a unique evidence reference number tied to the incident record
- The chain of custody documentation must record every transfer of evidence between individuals. Any gap in the chain of custody may compromise the admissibility of the evidence
- Physical evidence including devices, printed documents, and storage media must be stored in a locked cabinet in the Ottawa HQ server room accessible only to the IT Director and designated members of the IRT
- Digital evidence must be stored in an access-controlled, write-protected forensic evidence repository separate from production systems
- Evidence must be retained for a minimum of 7 years or for the duration of any associated legal proceedings, whichever is longer
- No evidence may be deleted, modified, or destroyed without written authorization from Legal Counsel

10. Incident Communication Guidelines

How NorthBridge communicates during an incident is as important as how it responds technically. Poor communication can worsen the impact of an incident, create legal liability, and damage client relationships beyond what the technical breach itself causes.

- All external communications about an incident must be approved by the Communications Lead (CEO or designated delegate) before being sent. This includes communications to clients, regulators, the media, and the public
- No employee, contractor, or IRT member may discuss the incident on social media, in public forums, or with individuals outside the IRT without explicit authorization from the Communications Lead
- Internal communications about the incident must be conducted via telephone or in person where possible during the active response phase. Email and messaging platforms may themselves be compromised and should not be used to share sensitive incident details until the environment is confirmed clean
- All media inquiries must be directed to the CEO without comment. No technical staff member is authorized to speak to the media about any security incident
- Communications with law enforcement must be coordinated through Legal Counsel to ensure that privileged communications are preserved and that NorthBridge's legal position is not compromised

11. Incident Reporting by Staff

Every member of the NorthBridge team has a responsibility to report suspected security incidents promptly. The effectiveness of the entire incident response program depends on early detection, and early detection depends on staff reporting.

11.1 How to Report

Security incidents must be reported by contacting the IT Director immediately by phone. The IT Director's emergency contact number is maintained on the NorthBridge intranet home page and is included in the annual security awareness training materials distributed to all staff.

For phishing emails specifically, use the Phish Alert Button in Microsoft Outlook. Do not forward phishing emails to colleagues and do not click any links or open any attachments in the email.

If the incident involves the IT Director personally or the IT Director is the suspected threat actor, report directly to the CEO.

11.2 What to Report

- Loss or theft of any NorthBridge device
- Receipt of a phishing email, particularly if any link was clicked or credentials were entered
- Any system behaving unexpectedly, including unusual slowness, unexpected pop-ups, or unexplained file changes
- Suspected unauthorized access to a NorthBridge account or system
- Accidental disclosure of sensitive information to an unauthorized party
- Discovery of an unauthorized individual in a restricted area
- Any request from an unknown individual for access credentials, system information, or client data
- Any suspicion that a colleague is misusing NorthBridge systems or accessing data beyond their role

11.3 Protection for Reporters

Employees who report security incidents in good faith will not face disciplinary action as a result of their report, even if the reported event turns out not to be a genuine incident. NorthBridge values early reporting above all else. The only circumstance in which a reporter may face consequences is if it is established that they deliberately made a false report with the intention of causing harm.

12. Roles and Responsibilities Summary

Role	Key Incident Response Responsibilities
IT Director (Incident Commander)	Overall accountability for all P1 and P2 incident responses. Classifies incidents, activates IRT, authorizes containment and eradication actions, approves all client and regulatory notifications, declares incidents resolved, and presents post-incident reports to CEO.
IT Manager (Technical Lead)	Leads technical investigation, evidence collection, and forensic activities. Maintains the incident log. Directs containment and eradication activities. Escalates to MSSP or Microsoft for support when internal capacity is exceeded.

CEO (Communications Lead)	Approves all external communications including client and regulatory notifications. Manages media inquiries. Notified within 1 hour of all P1 incidents and within 4 hours of all P2 incidents.
Legal Counsel	Advises regulatory notification obligations. Reviews all external communications. Manages evidence of preservation and chain of custody requirements. Coordinates law enforcement engagement.
HR Manager	Engaged in incidents with an insider threat component. Manages any resulting disciplinary process in accordance with employment law.
All Employees and Contractors	Report suspected incidents immediately to the IT Director. Do not investigate, remediate, or communicate about incidents independently. Follow instructions from the IRT during an active incident without delay.

13. Testing and Continuous Improvement

An incident response policy that has never been tested is an untested plan. NorthBridge commits testing and improving its incident response capability on an ongoing basis through the following activities.

Activity	Description	Frequency
Tabletop Exercise	A facilitated discussion-based exercise in which the IRT walks through a simulated incident scenario to test decision-making, communication, and escalation processes without affecting live systems.	Annual minimum. Additional exercises recommended following a significant real incident.
Phishing Simulation	Simulated phishing emails sent to all staff to test detection and reporting behaviour. Results used to target additional training to staff who fail the simulation.	Quarterly
Incident Response Plan Review	Full review of this policy and all supporting incident response documentation to ensure it remains current and accurate.	Annual, or following any P1 or P2 incident
Contact List Verification	Verification that all emergency contact details for IRT members, GoC clients, regulators, and external support providers are current and accurate.	Quarterly

14. Policy Review and Approval

This policy is reviewed annually by the IT Director and approved by the Chief Executive Officer. The policy is also reviewed following any P1 or P2 security incident to incorporate lessons learned from the response.

Role	Name	Signature	Date
Author	Ashkon Irani	[Signed]	05/17/2026
Reviewer	IT Director	[Signed]	05/17/2026
Approver	Chief Executive Officer	[Signed]	05/17/2026

-- End of Document --

POL-004 v1.0 | NorthBridge Technology Solutions Inc. | CONFIDENTIAL